THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 8

Intrusion Detection and Prevention Systems

Objectives

- Identify the components of an intrusion detection and prevention system
- Describe options for implementing intrusion detection and prevention systems
- Explain the steps of intrusion detection

© Cengage Learning 2014

Goals of an IDPS, Part 1

- Network intrusion
  - Attempt to gain unauthorized access to network resources
- Intrusion Detection and Prevention System (IDPS)
  - Consists of more than one application or hardware device
  - Incorporates more than just detection
- Intrusion detection and prevention
  - Involves prevention, detection, and response

© Cengage Learning 2014

Intrusion Detection and Prevention

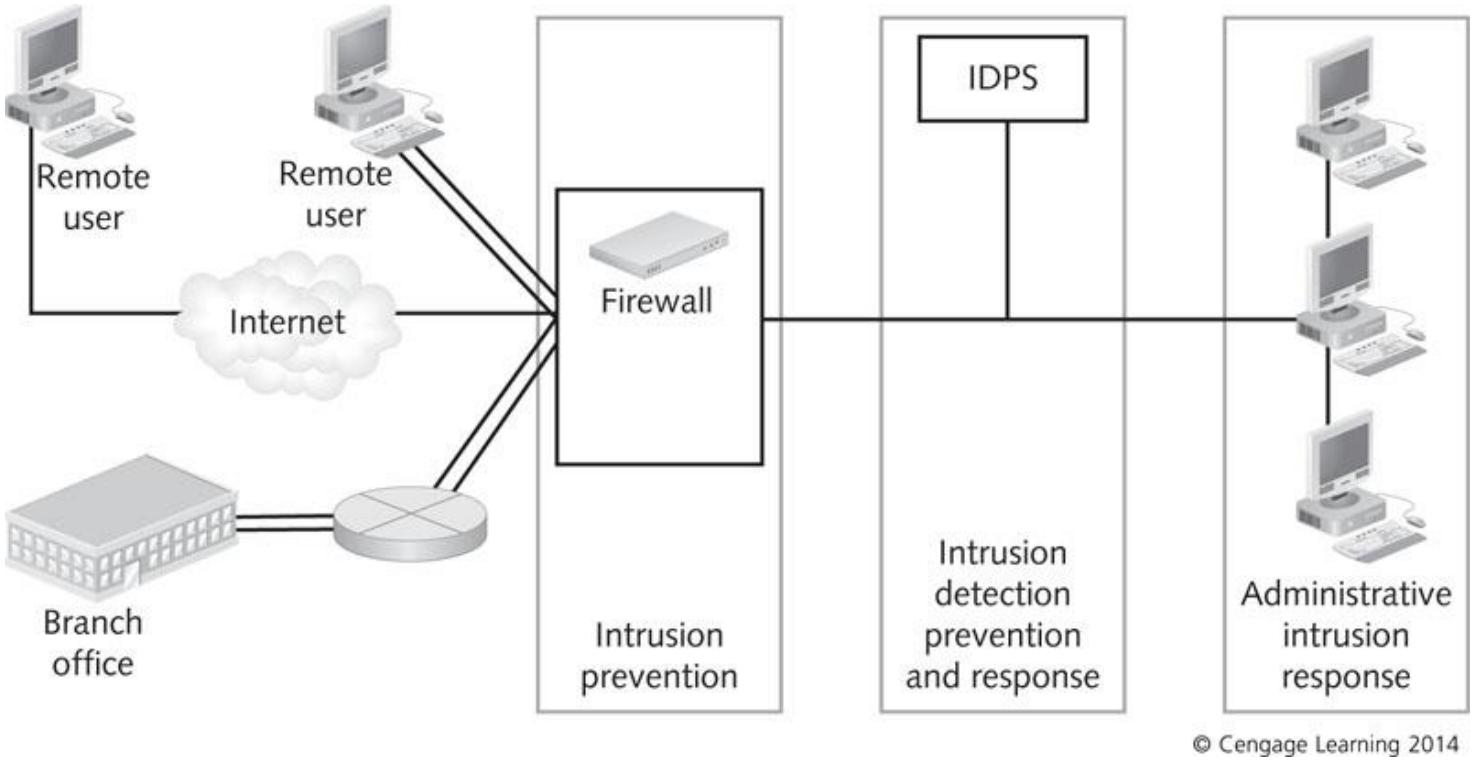


Figure 8-1 The role of intrusion detection and prevention in network defense

Goals of an IDPS, Part 2

- An IDPS should be able to:
  - Assess large volumes of network traffic or system activity to find signs of unauthorized access
  - Record its findings in a log so that administrators can examine past activity
  - Detect and record unauthorized access without compromise to produce evidence admissible in court
  - Respond almost immediately
  - Make itself and systems it protects as inaccessible as possible to attackers

© Cengage Learning 2014

Anomaly and Signature Detection Systems, Part 1

- Anomaly detection system: makes use of profiles that describe services and resources each authorized user normally accesses
  - Network baselines are associated with profiles
  - System can monitor profiles for suspicious activity that does not fit the profiles
- IDPS can create baselines by monitoring network traffic to observe what is considered normal behavior

© Cengage Learning 2014

Anomaly and Signature Detection Systems, Part 2

- If profiles are incomplete or inaccurate:
  - IDPS sends alarms that **false positives** (legitimate traffic rather than actual attacks)
  - **False negatives** (genuine attacks that an IDPS does not detect) could occur
- **True negatives**: legitimate communications that do not set off an alarm
- **True positive**: used to describe a genuine attack that an IDPS detects successfully

© Cengage Learning 2014

Anomaly and Signature Detection Systems, Part 3

- Signature detection: triggers alarms based on characteristic signatures of known external attacks
- Signature-based IDPS best for companies that want a basic IDPS and mostly concerned with known attacks
  - Network engineers research well-known attacks and record rules associated with each signature
  - Signatures should be updated regularly

© Cengage Learning 2014

Advantages and Disadvantages of Detection Systems, Part 1

Detection method	Advantages	Disadvantages
Anomaly	Because an anomaly detection system is based on profiles an administrator creates, an attacker cannot test the IDPS beforehand and anticipate what will trigger an alarm.	Configuring the IDPS to use profiles of network users and groups requires considerable time.
	As new users and groups are created, IDPS profiles can be updated to keep up with these changes.	Updating IDPS profiles can be time consuming.
	Because an anomaly detection system does not rely on published signatures, it can detect new attacks.	The definition of what constitutes normal traffic changes constantly, and the IDPS must be reconfigured to keep up.
	The system can detect attacks from inside the network by employees or attackers who have stolen employee accounts.	After installation, the IDPS must be trained for days or weeks to recognize normal traffic.
Signature	This approach makes use of signatures of well-known attacks.	The database of signatures must be updated to maintain the IDPS's effectiveness.

Table 8-1 Advantages and disadvantages of detection systems

Advantages and Disadvantages of Detection Systems, Part 2

Detection method	Advantages	Disadvantages
	This IDPS can begin working immediately after installation.	New types of attacks might not be included in the database.
	This IDPS is easy to understand and less difficult to configure than an anomaly-based system.	By making minor alterations to an attack, attackers can avoid matching a signature in the database.
	Each signature in the database is assigned a number and name so that the administrator can specify which attacks should set off an alarm.	Because a misuse-based system requires a database, extensive disk storage space might be needed.

Table 8-1 Advantages and disadvantages of detection systems (continued)

Stateful Protocol Analysis, Part 1

- Stateful protocol analysis: information gathering about a connection
  - When an IDPS receives a packet, connection information between the host and remote computer is compared to entries in a state table
  - State table: maintains a record of connections between computers
    - Includes: source and destination IP address and port, and protocol
- Event horizon: entire length of the attack
  - IDPS needs to maintain state information during this

© Cengage Learning 2014

Stateful Protocol Analysis, Part 2

- Stateful protocol analysis approaches:
  - Traffic rate monitoring – If IDPS detects sudden increase in traffic it can stop and reset all TCP traffic
  - Protocol state tracking – IDPS maintains a record of connection's state and allows packets to pass through if it is an established connection
  - Dynamic Application layer protocol analysis – Can identify applications not using standard ports
  - IP packet reassembly – Can reassemble fragmented packets to prevent fragments from passing through to the internal network

© Cengage Learning 2014

Examining IDPS Components

- Components
  - Network sensors or host-based agents
  - Detection and prevention capabilities
  - Command console
  - Database server that stores attack signatures or behaviors

© Cengage Learning 2014

Sensors and Agents, Part 1

- Sensor or agent
  - Functions as electronic “eyes” of an IDPS
  - Host-based IDPS – IDPS installed on a single host computer has its agent built into the IDPS software
  - Network-based IDPS – sensor is hardware or software that monitors network traffic in real time
  - Attacks detected by an IDPS sensor
    - Single-session attacks – isolated attempt
    - Multiple-session attacks – take place over a period of time

© Cengage Learning 2014

Sensors and Agents, Part 2

- Sensors should be placed at common-entry points
  - Internet gateways
  - Connections between one network and another
  - Remote access server that receives dial-up connections from remote users
  - Virtual private network (VPN) devices
- Sensors could be positioned at either side of the firewall
  - Behind the firewall is a more secure location
- IDPS management server: central repository for sensor and agent data

© Cengage Learning 2014

Positioning Sensors at Entry Points

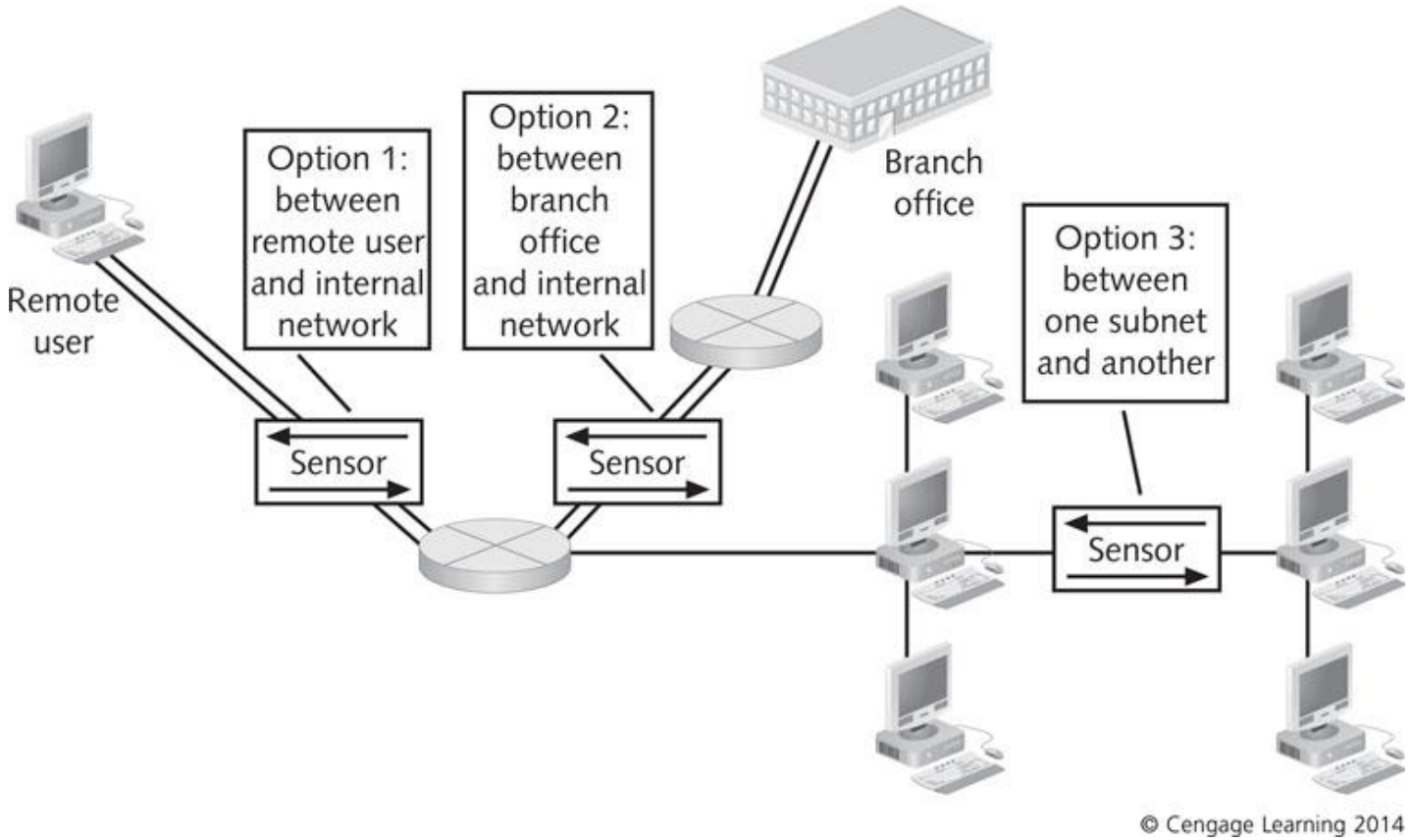


Figure 8-2 Positioning sensors at entry points to the network

Positioning Sensors Behind the Firewall

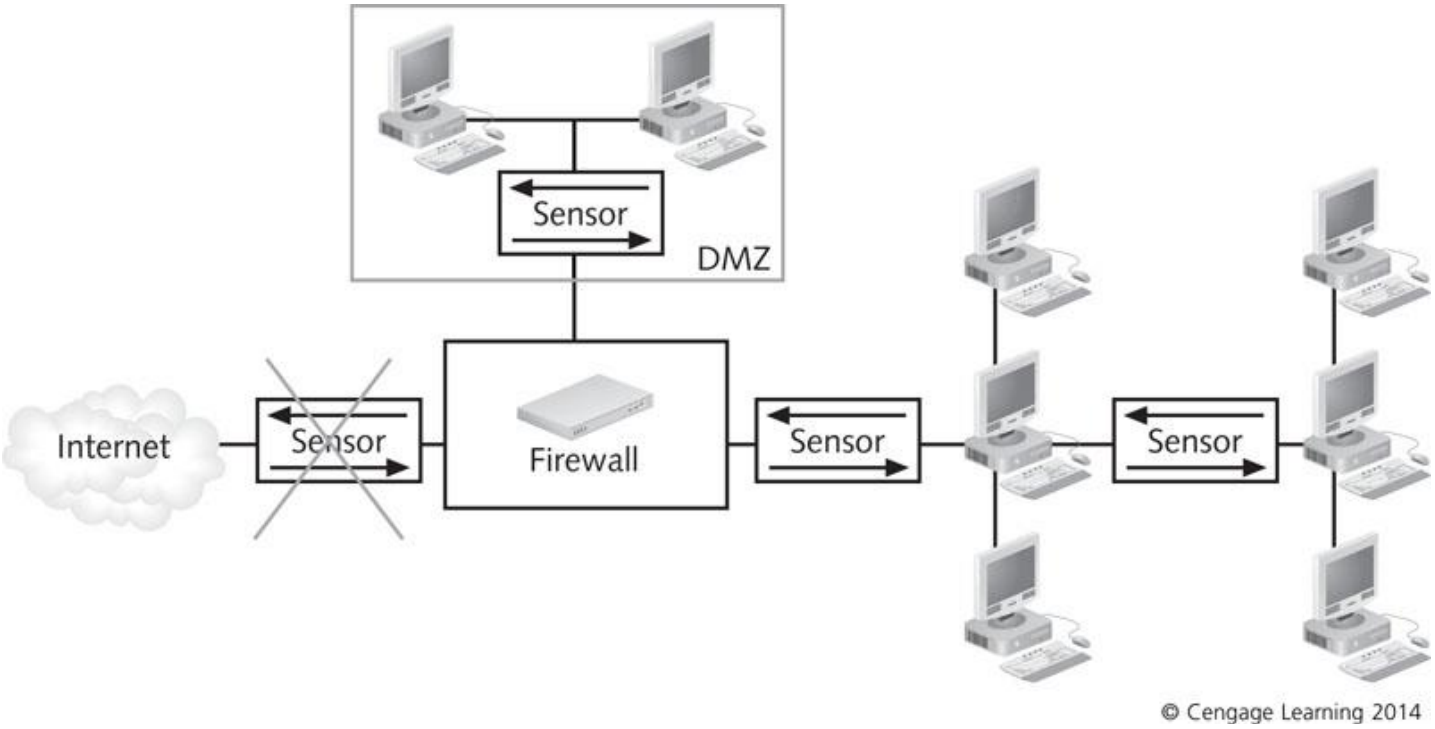


Figure 8-3 Positioning sensors behind the firewall in the DMZ

Detection and Prevention Capabilities, Part 1

- When selecting an IDPS, consider the following:
  - *Threshold* – Values that set the limit between normal and abnormal behavior
  - *Blacklists* – lists of entities that have been associated with malicious activity
  - *Whitelists* – lists of entities known to be harmless
  - *Alert settings* – specifying default priorities or severity levels, determining which prevention capabilities should be used for certain events, and specifying what information should be logged

© Cengage Learning 2014

Detection and Prevention Capabilities, Part 2

- Prevention Capabilities
  - IDPS can be configured to take preventative countermeasures
    - Example: resetting all network connections when an intrusion is detected
  - Some IDPSs allow administrators to specify which measure should be taken for each alert type
  - Some have a simulation mode in which all prevention capabilities are disabled but generate reports used to fine-tune prevention capabilities

© Cengage Learning 2014

Command Console

- Provides a graphical front-end interface to an IDPS
  - Enables administrators to receive and analyze alert messages and manage log files
- IDPS can collect information from security devices throughout a network
- Command console should run on a computer dedicated solely to the IDPS
  - To maximize the speed of response

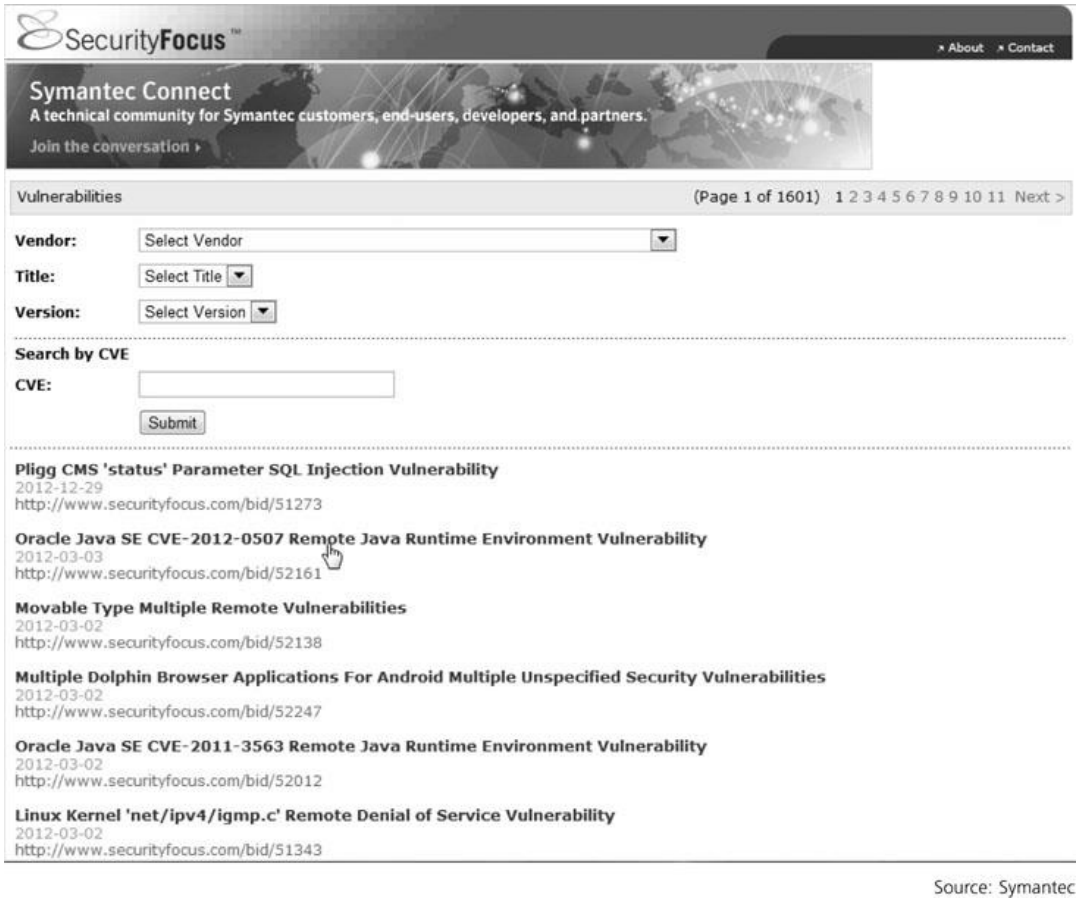
© Cengage Learning 2014

Database of Attack Signatures or Behaviors

- IDPSs do not have the capability to use judgment
  - Can make use of a source of information for comparing the traffic they monitor
- Signature-detection IDPS
  - Reference a database of known attack signatures
  - If traffic matches a signature, it sends an alert
- Keep database updated
- Anomaly-based IDPS
  - Store information about users in a database

© Cengage Learning 2014

Online Database of Known Vulnerabilities



Source: Symantec

Figure 8-4 The SecurityFocus online database of known vulnerabilities

© Cengage Learning 2014

Options for IDPSs

- Network-based IDPS
- Host-based IDPS
- Hybrid IDPS

© Cengage Learning 2014

Network-Based IDPSs, Part 1

- Network-based IDPS (NIDPS)
  - Monitors network traffic by using well-positioned sensors, management servers, a command console, and a signature database
  - Can be hardware devices equipped with NICs for capturing and analyzing packets
  - Can also be software-based sensors installed on a dedicated computer
  - Positioning an NIDPS on the Network
    - Behind the firewall and before the LAN
    - Between the firewall and the DMZ
    - Any network segment

© Cengage Learning 2014

Network-Based IDPSs, Part 2

- An NIDPS can use:
  - Inline sensors – positioned so that network traffic must pass through it
    - Used to stop attacks from blocking network traffic
    - Usually placed where firewalls are positioned
  - Passive sensors – monitor copies of traffic; no actual traffic passes through them
    - Can monitor traffic by:
      - *Spanning port*
      - *Network tap*
      - *IDPS load balancer*

© Cengage Learning 2014

Positioning an Inline Sensor

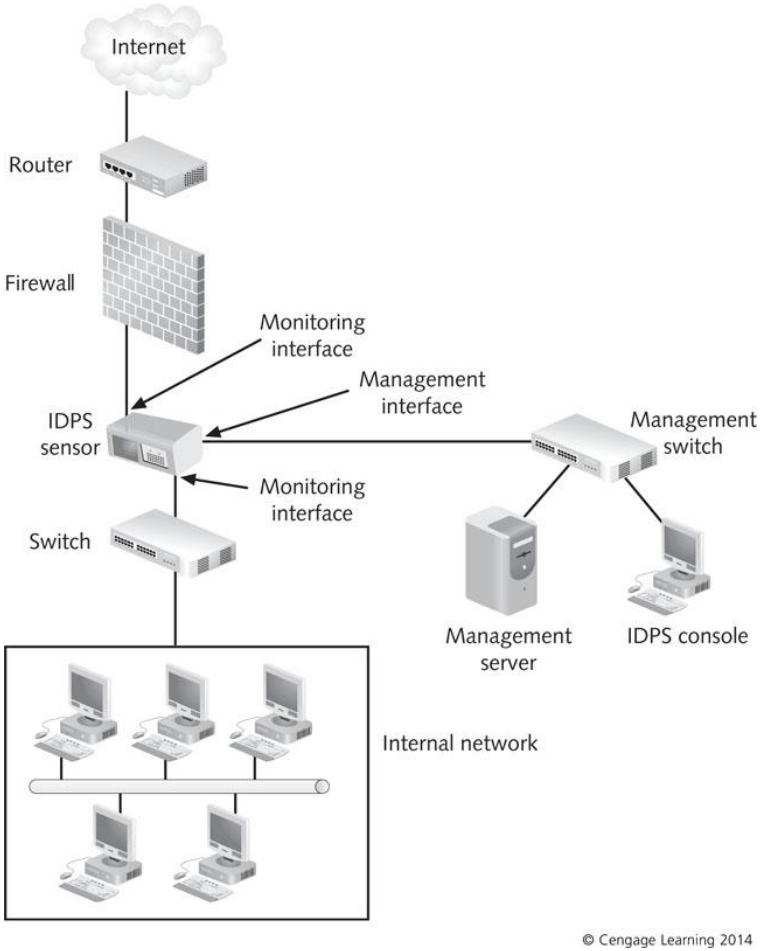


Figure 8-6 Positioning an inline sensor

Positioning a Passive Sensor

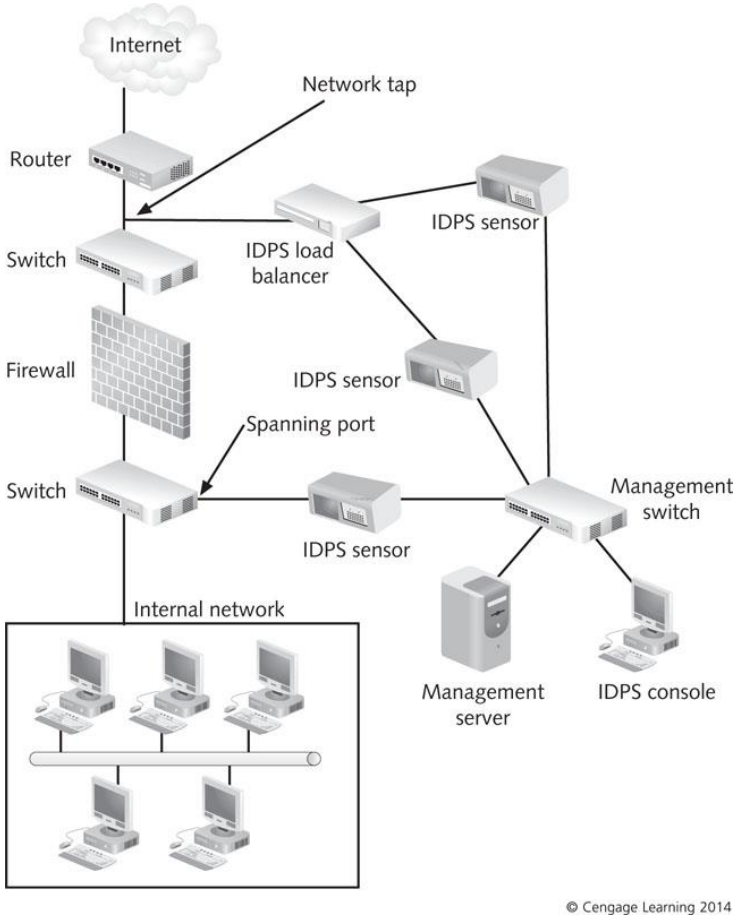


Figure 8-7 Positioning a passive sensor

Network-Based IDPSs, Part 3

- NIDPS Capabilities
  - Vary depending on product
  - Some can:
    - Collect information about hosts, OSs, applications, and network activities and characteristics
      - Used to help identify vulnerable hosts
    - Analyze packet headers to identify unusual behavior
  - Most have traffic logs to help identify and analyze potential attacks, locate vulnerabilities, and assess network use and performance

© Cengage Learning 2014

Network-Based IDPSs, Part 4

- NIDPS prevention capabilities vary based on sensor types:
  - Passive only – Ends the current TCP session
  - Inline only – Uses inline firewalling and bandwidth throttling, and alters malicious content
  - Passive and inline – Reconfigures other network security devices
- Administrators can configure specific actions for each type of alert

© Cengage Learning 2014

Network-Based IDPSs, Part 5

- NIDPS Management
  - Designing architecture includes:
    - Determining where sensors are located
    - How many are needed and how they should be connected
  - Testing NIDPS components includes:
    - Accounting for network downtime while deploying sensors
  - Securing components involves:
    - Making sure sensors do not have IP addresses
    - Hardening management networks and configuring hosts for log files and backups

© Cengage Learning 2014

Host-Based IDPSs, Part 1

- Host-based IDPS (HIDPS)
  - Deployed on hosts in the network perimeter
  - Commonly use management servers, signature databases, and console
  - Evaluates traffic generated by the host
    - Often used to protect a Web server or database server
  - Gathers system variables such as
    - System processes, CPU use, file accesses, system logs, and system and application configuration changes
  - Does not sniff packets as they enter the LAN
    - Monitors log file entries and user activity

© Cengage Learning 2014

A Typical HIDPS Deployment

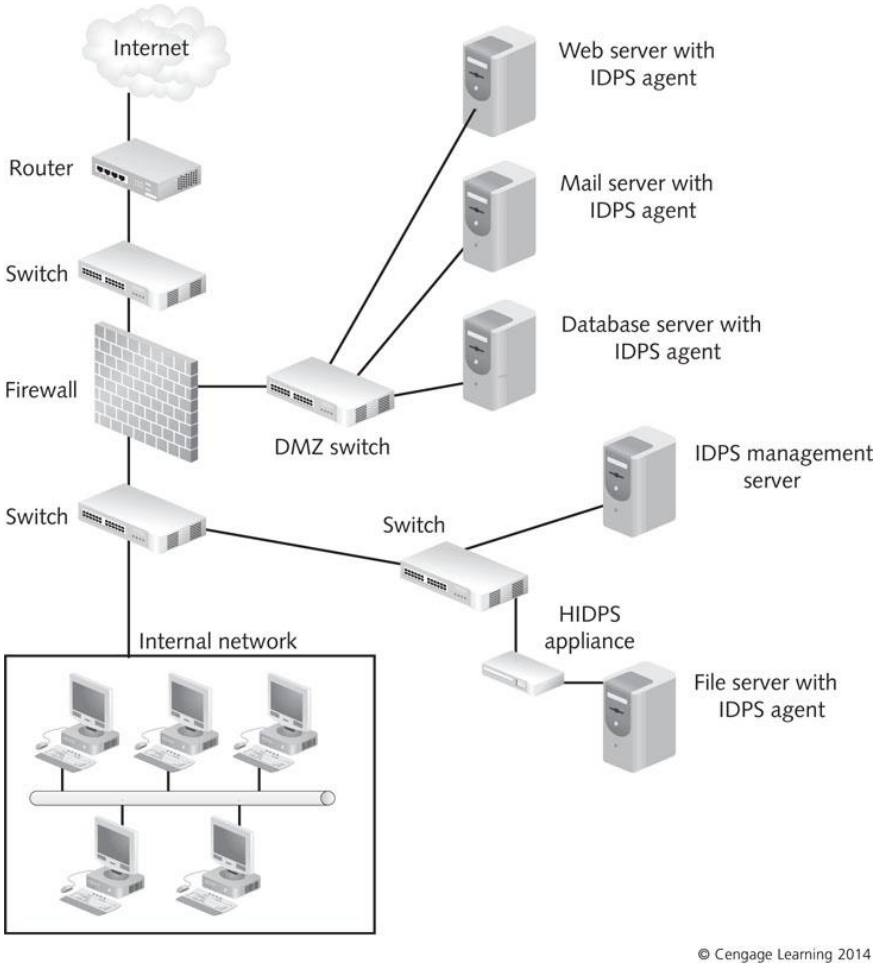


Figure 8-8 A typical HIDPS deployment

Host-Based IDPSs, Part 2

- Configuring an HIDPS
  - Centralized configuration
    - HIDPS sends all data to a central location
    - Host's level of performance is unaffected by the IDPS
    - Alert messages that are generated do not occur in real time
  - Distributed configuration
    - Processing of events is distributed between host and console
    - Host generates and analyzes it in real time
    - Performance reduction in host

© Cengage Learning 2014

A Centralized HIDPS

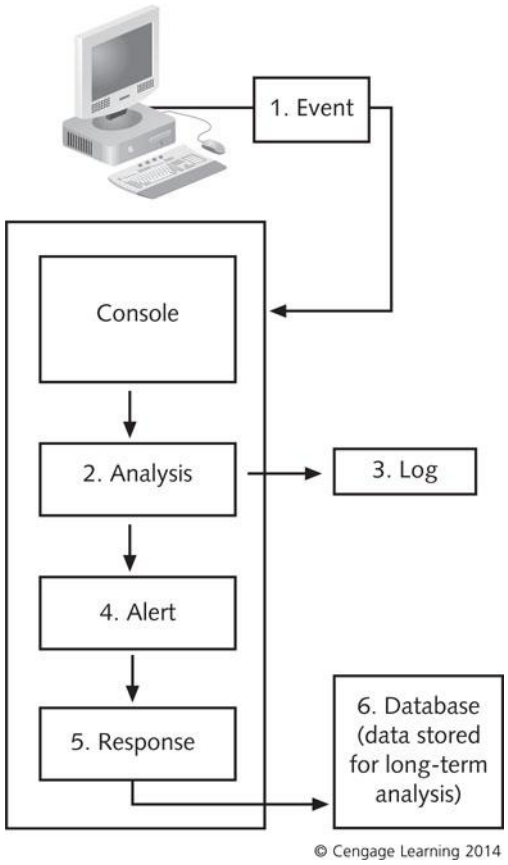


Figure 8-9 A centralized HIDPS

Processing Event Data from an HIDPS

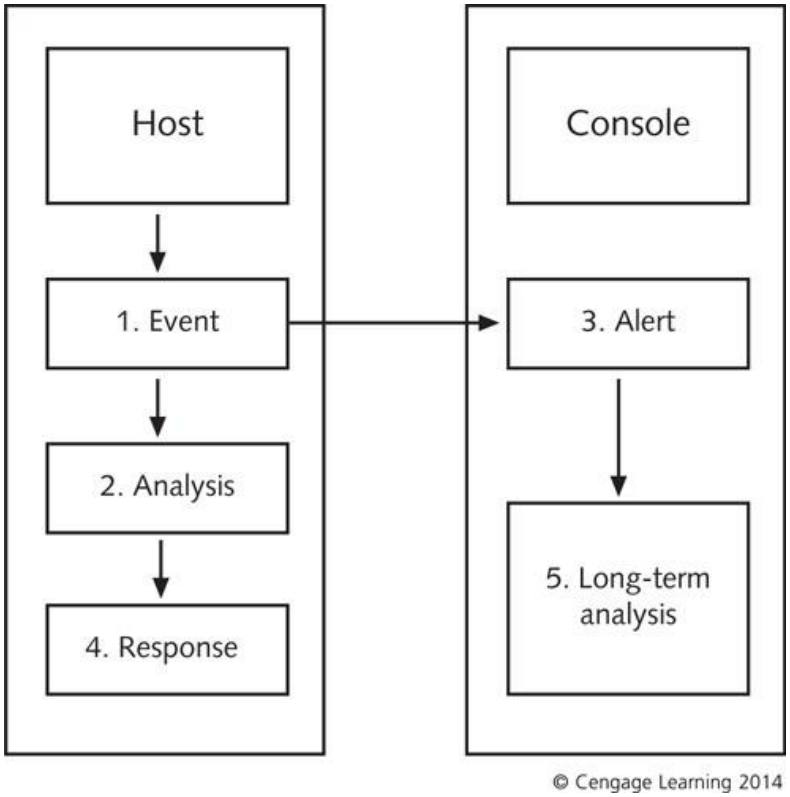


Figure 8-10 Processing event data from an HIDPS

Host-Based IDPSs, Part 3

- Choosing the Host
  - Centralized configuration
    - RAM, hard disk memory, and processor speed requirements are minimal
  - Distributed configuration
    - Host should be equipped with maximum memory and processor speed

© Cengage Learning 2014

Comparing an NIDPS and HIDPS

- HIDPS
  - Can tell whether an attack attempt was successful
  - Can detect attacks that would get past NIDPS
  - Provides only data pertaining to the host, not network as a whole
  - Compares records stored in audit logs
- NIDPS
  - Provides alerts on suspicious network activity
    - Does not tell whether attack occurred
  - Detects attacks on network
    - Such as port scanning on a range of computers

© Cengage Learning 2014

Hybrid IDPSs, Part 1

- Hybrid IDPS
  - Combines the features of HIDPSs and NIDPSs
    - Gains flexibility and increases security
- Combining IDPS Sensor Locations
  - Put sensors on network segments and network hosts
  - Can report attacks aimed at particular segments or the entire network

© Cengage Learning 2014

Hybrid IDPSs, Part 2

- Combining IDPS Detection Methods
  - IDPS combines anomaly and signature detection
  - Database of known attack signatures enables IDPS to run immediately
  - Anomaly-based systems keep the alert system flexible
  - A hybrid IDPS that combines anomaly and signature detection can respond to both external and internal attacks
  - Administrators have more configuration and coordination work to do

© Cengage Learning 2014

Hybrid IDPSs, Part 3

- Advantages
  - Combine aspects of NIDPS and HIDPS configurations
  - Can monitor network as a whole
  - Can monitor attacks that reach individual hosts
- Disadvantages
  - Getting disparate systems to work in coordinate fashion
  - Data gathered by multiple systems can be difficult to analyze

© Cengage Learning 2014

Securing IDPS Components

- IDPS must be able to handle the volume of traffic or activity it encounters
- IDPSs should be tested regularly
- Sensors should not be addressable
- Communication between IDPS components should be encrypted
- Authentication should be required for use and administration of the IDPS
- IDPSs should be able to work during DoS attacks
- Remote logging should be used in an HIDPS
- OSs of HIDPSs should be patched and hardened

© Cengage Learning 2014

Developing IDPS Filter Rules

- To create IDPS filter rules you must know basics of Snort rule syntax
  - Snort rule has two sections: header and options
- Example:
  - Alert tcp any any -> 192.16.21.0/24 111 (content: “00 01 86 a5” ; msg: “mounted access”;)
  - Header is the opening portion
  - Options are in parentheses

© Cengage Learning 2014

Examining Intrusion Detection Step by Step

- Steps
  - Installing the IDPS database
  - Gathering data
  - Sending alert messages
  - The IDPS responds
  - The administrator assesses damage
  - Following escalation procedures
  - Logging and reviewing events

© Cengage Learning 2014

Steps in Intrusion Detection

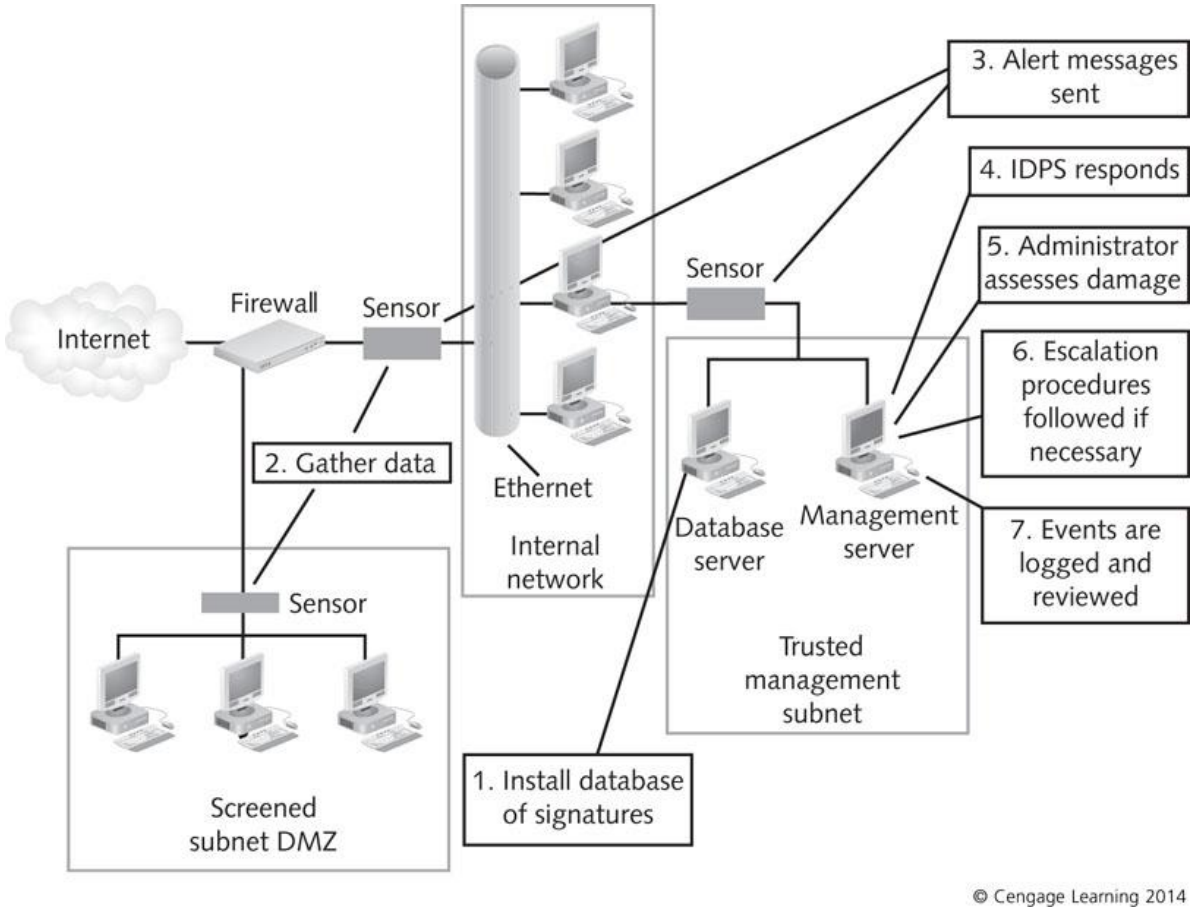


Figure 8-11 Steps in intrusion detection

© Cengage Learning 2014

Step 1: Installing the IDPS Database

- IDPS uses the database to compare traffic detected by sensors
- Anomaly-based systems
  - Requires compiling a network baseline by observing network traffic (over a week)
- Signature-based IDPS
  - Can use database immediately
  - You can add your own custom rule base

© Cengage Learning 2014

Step 2: Gathering Data

- Network sensors gather data by reading packets
- Sensors need to be positioned where they can capture all packets
  - Sensors on individual hosts capture information that enters and leaves the host
  - Sensors on network segments read packets as they pass throughout the segment
- Sensors on network segments cannot capture all packets
  - If traffic levels become too heavy

© Cengage Learning 2014

Step 3: Sending Alert Messages

- IDPS detection software compares captured packets with information in its database
- IDPS sends alert messages
  - If captured packets match an attack signature or
  - Deviates from normal network behavior

© Cengage Learning 2014

Step 4: The IDPS Responds

- Command console receives alert messages
  - Notifies the administrator
- IDPS response actions:
  - Alarm - Send an alarm message
  - Drop – Packet is dropped
  - Reset – IDPS stops and restarts network traffic
  - Code analysis – Prevents malicious code from running
  - File system monitoring – Prevent files from being modified
  - Network traffic filtering – act as firewall
  - Network traffic analysis – stop incoming traffic

© Cengage Learning 2014

Step 5: The Administrator Assesses Damage

- Administrator monitors alerts
  - Determines whether countermeasures are needed
- Administrator need to fine-tune the database
  - The goal is avoiding false negatives
- Line between acceptable and unacceptable network use is not always clear

© Cengage Learning 2014

Differentiating Acceptable and Unacceptable Network Use

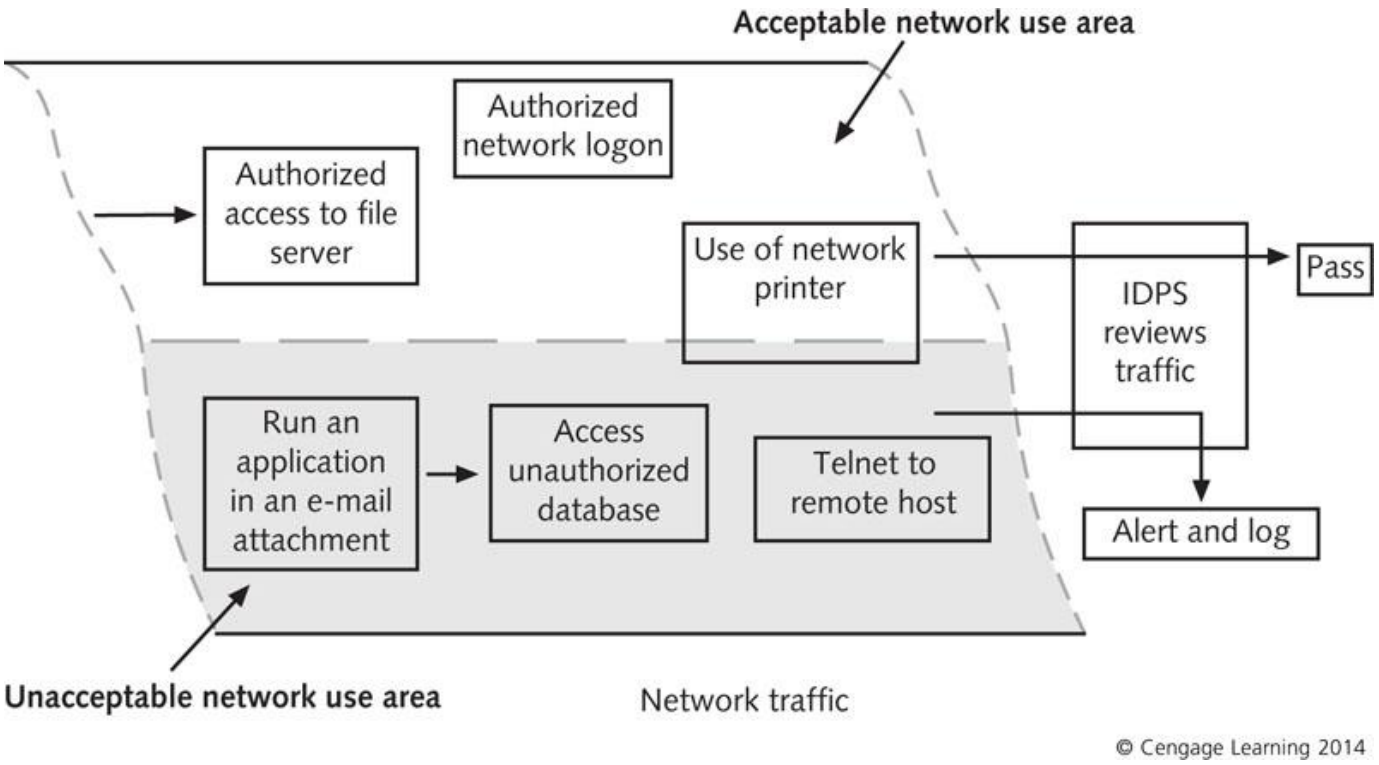


Figure 8-12 Differentiating acceptable and unacceptable network use

Step 6: Following Escalation Procedures

- Escalation procedures
  - Set of actions to be followed if the IDPS detects a true positive
- Should be spelled out in company's security policy
- Incident levels
  - Level One
    - Might be managed quickly
  - Level Two
    - Represents a more serious threat
  - Level Three
    - Represents the highest degree of threat

© Cengage Learning 2014

Step 7: Logging and Reviewing the Event

- IDPS events are stored in log files
  - May also be sent to a database file
- Administrator should review logs
  - To determine patterns of misuse
  - Administrator can spot a gradual attack
- IDPS should also provide **accountability**
  - Ability to track an attempted attack or intrusion back to the responsible party
  - Some systems have built-in tracing features

© Cengage Learning 2014

Evaluating IDPS Products, Part 1

- Evaluate the various options and match them to your needs
- Consider the following basic factors:
  - Determine whether an IDPS is necessary
  - Conduct a risk assessment
  - Define general requirements and goals an IDPS should meet
  - Determine whether to use proprietary or open-source products
  - Consider the frequency and accuracy of signature updates
  - Assess availability of support

© Cengage Learning 2014

Evaluating IDPS Products, Part 2

- Consider the following basic factors (cont'd):
  - Evaluate technical specifications
  - Determine external security requirements
  - Evaluate need for security capabilities and logging
  - Review detection and prevention capabilities
  - Identify performance and management requirements
  - Define the interoperability and scalability
  - Determine a reasonable cost estimate that includes acquisition, testing, installation, and maintenance
  - Identify resource limitations
  - Identify any training, documentation, and support needed

© Cengage Learning 2014

Summary, Part 1

- Intrusion detection and prevention systems (IDPSs) add another line of defense behind firewalls and antivirus software
- IDPS components include sensors, management servers, command consoles, and databases of signatures
- A network-based IDPS (NIDPS) uses sensors positioned at key points on the network
- A host-based IDPS (HIDPS) deploys agents on selected hosts in the network

© Cengage Learning 2014

Summary, Part 2

- A hybrid IDPS combines aspects of NIDPS and HIDPS configurations
- Selecting an IDPS requires evaluating the organization's needs and security goals and the product's features
- Steps of intrusion detection include: installing the IDPS and signature database, gathering data, sending an alert, responding to the alert, assessing damage, following escalation procedures, and logging and reviewing events

© Cengage Learning 2014